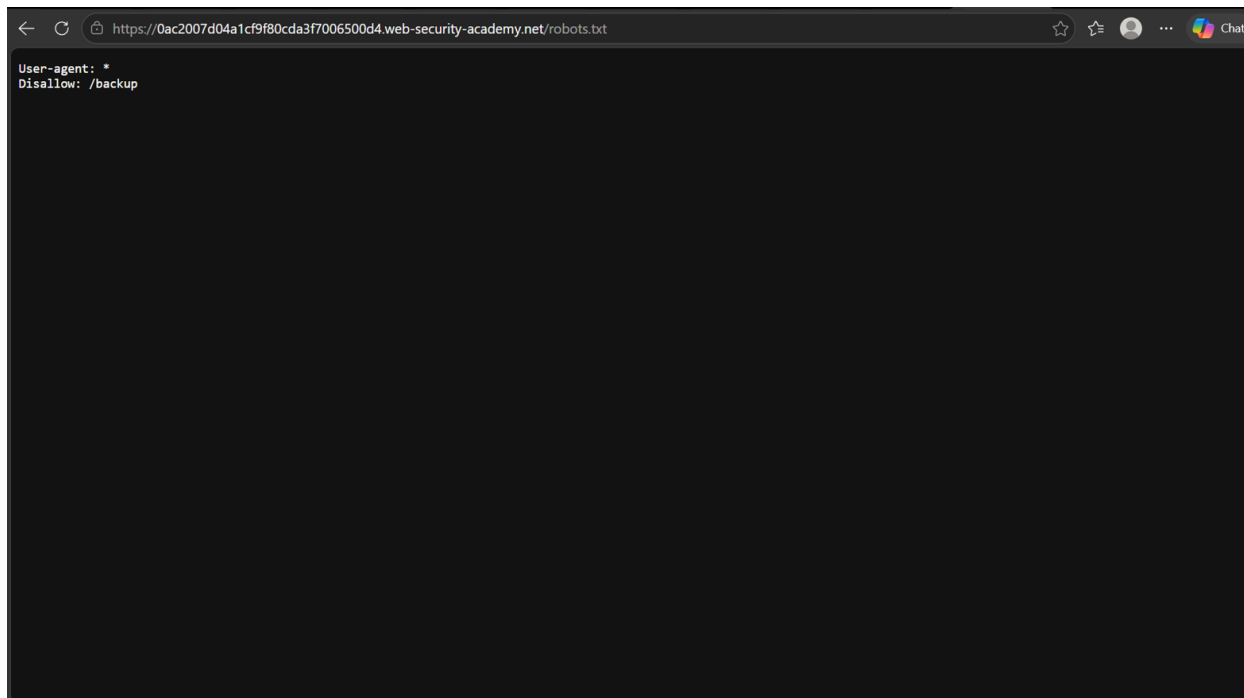


Lab: Source code disclosure via backup files

Mục tiêu: Tìm source code bị lộ qua các file backup mà developer vô tình để lại.

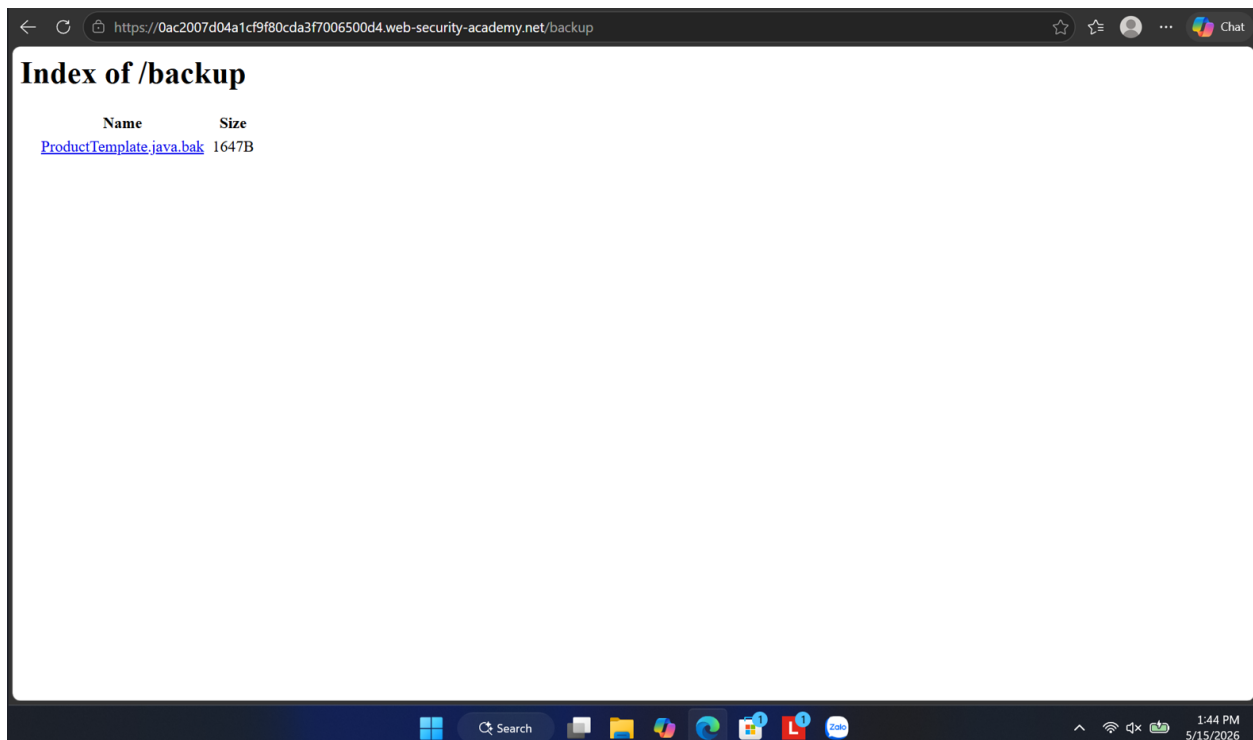
Bước 1. Mở lab trên PortSwigger sau đó copy URL của lab

Bước 2. Nhập đường link URL vào rồi thêm **/robots.txt**



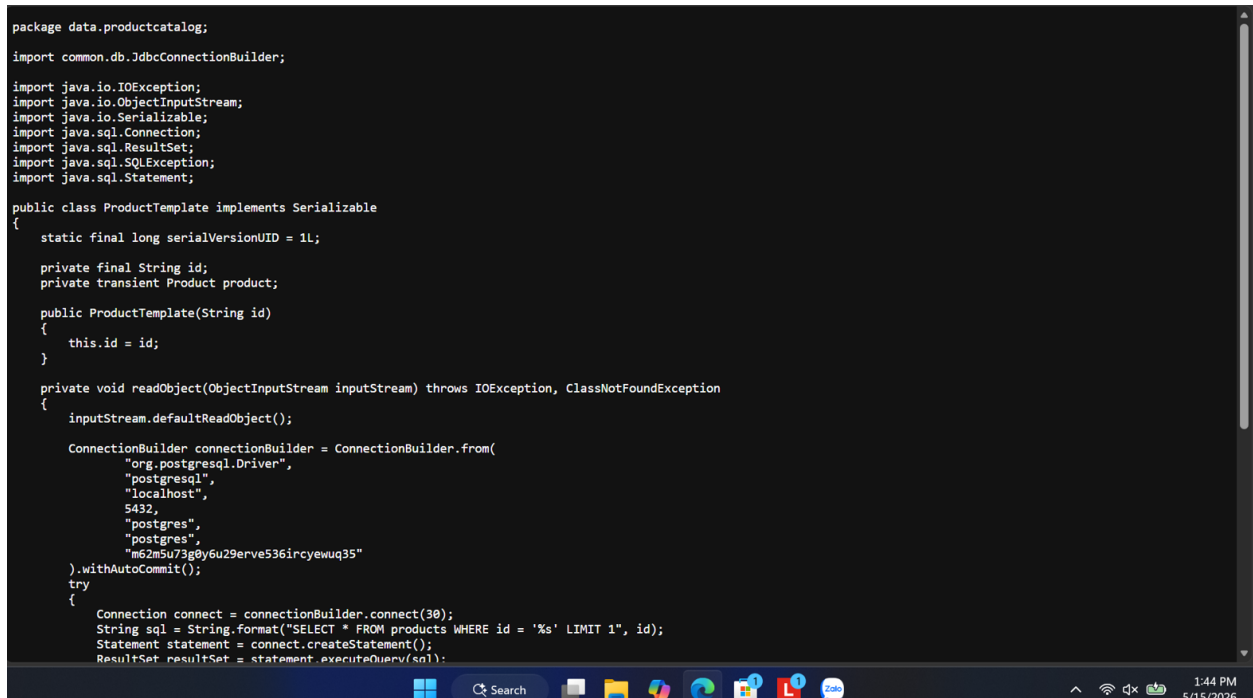
-Robots.txt là một file nằm ở thư mục gốc của website dùng để hướng dẫn các bot tìm kiếm như Googlebot cách thu thập dữ liệu trên trang web, trong bài lab để nó liệt kê các thư mục ẩn.

Bước 3. Chạy luôn link URL đó đằng sau là **/backup**



-Ở đây nó sẽ hiện ra 1 cái file backup

Bước 4. Click vào file backup đó **ProductTemplate.java.bak**



Bước 5. Dò password

```
import java.sql.SQLException;
import java.sql.Statement;

public class ProductTemplate implements Serializable
{
    static final long serialVersionUID = 1L;

    private final String id;
    private transient Product product;

    public ProductTemplate(String id)
    {
        this.id = id;
    }

    private void readObject(ObjectInputStream inputStream) throws IOException, ClassNotFoundException
    {
        inputStream.defaultReadObject();

        ConnectionBuilder connectionBuilder = ConnectionBuilder.from(
            "org.postgresql.Driver",
            "postgresql",
            "localhost",
            5432,
            "postgres",
            "postgres",
            "m62m5u73g0y6u29erve536ircyewuq35"
        ).withAutoCommit();
        try
        {
            Connection connect = connectionBuilder.connect(30);
            String sql = String.format("SELECT * FROM products WHERE id = '%s' LIMIT 1", id);
            Statement statement = connect.createStatement();
            ResultSet resultSet = statement.executeQuery(sql);
            if (!resultSet.next())
            {
                return;
            }
            product = Product.from(resultSet);
        }
        catch (SQLException e)
        {
            throw new IOException(e);
        }
    }
}
```

Bước 6. Lấy password rồi vào web submit password



Source code disclosure via backup files

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!   [Continue learning >>](#)

[Home](#)

WE LIKE TO SHOP 



Grow Your Own Spy Kit



Vintage Neck Defender



Fur Babies

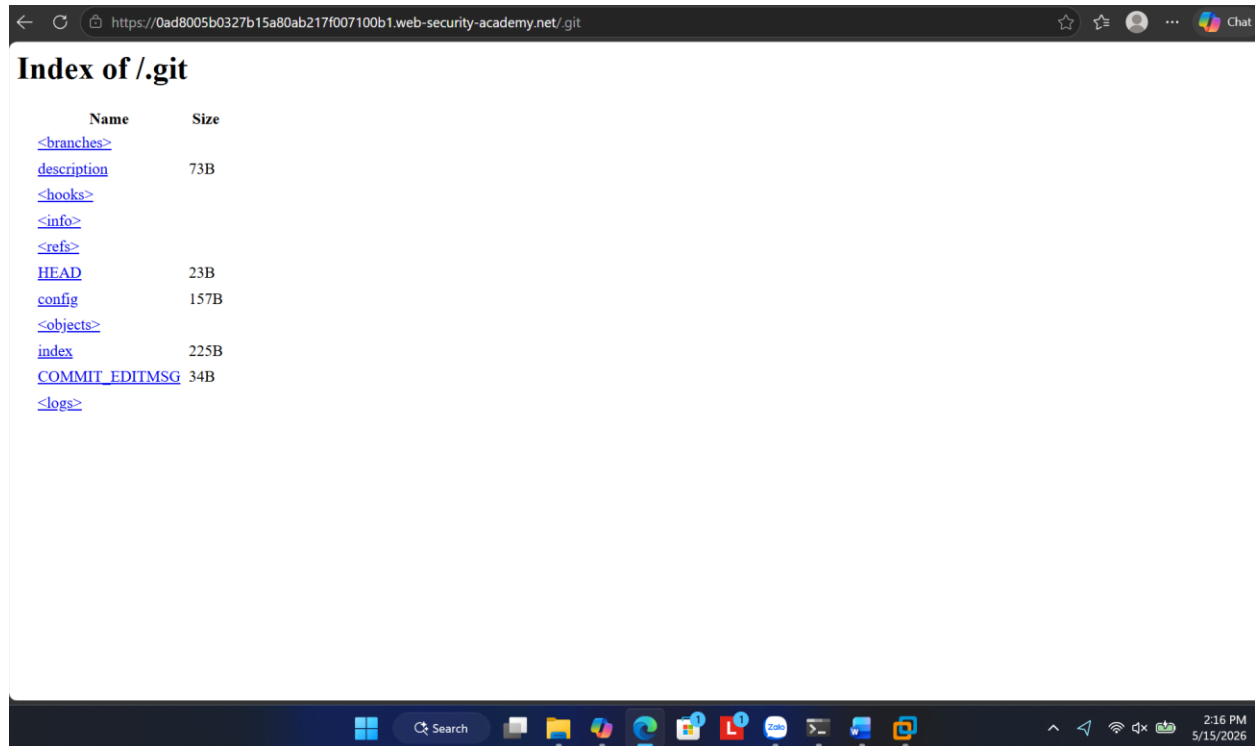


Hydrated Crackers

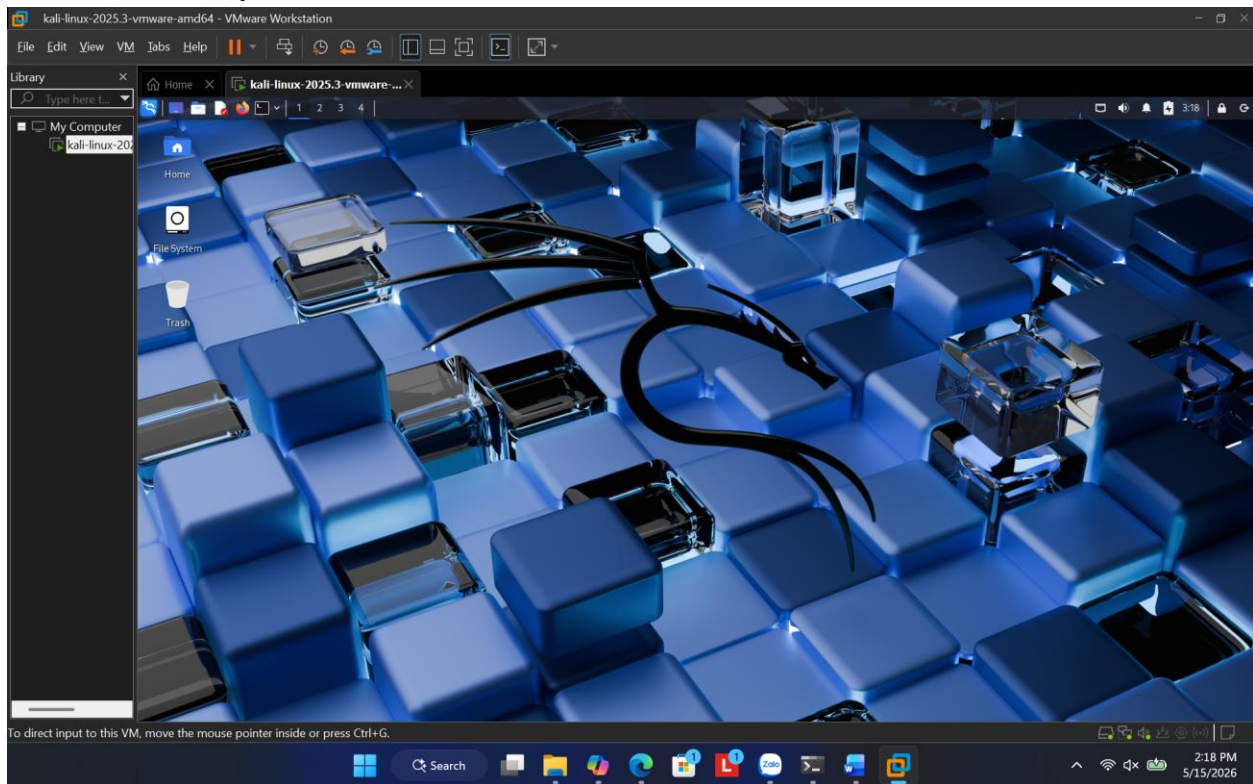
Lab: Information disclosure in version control history

Mục tiêu: Khai thác lịch sử Git bị để lộ công khai trên server.

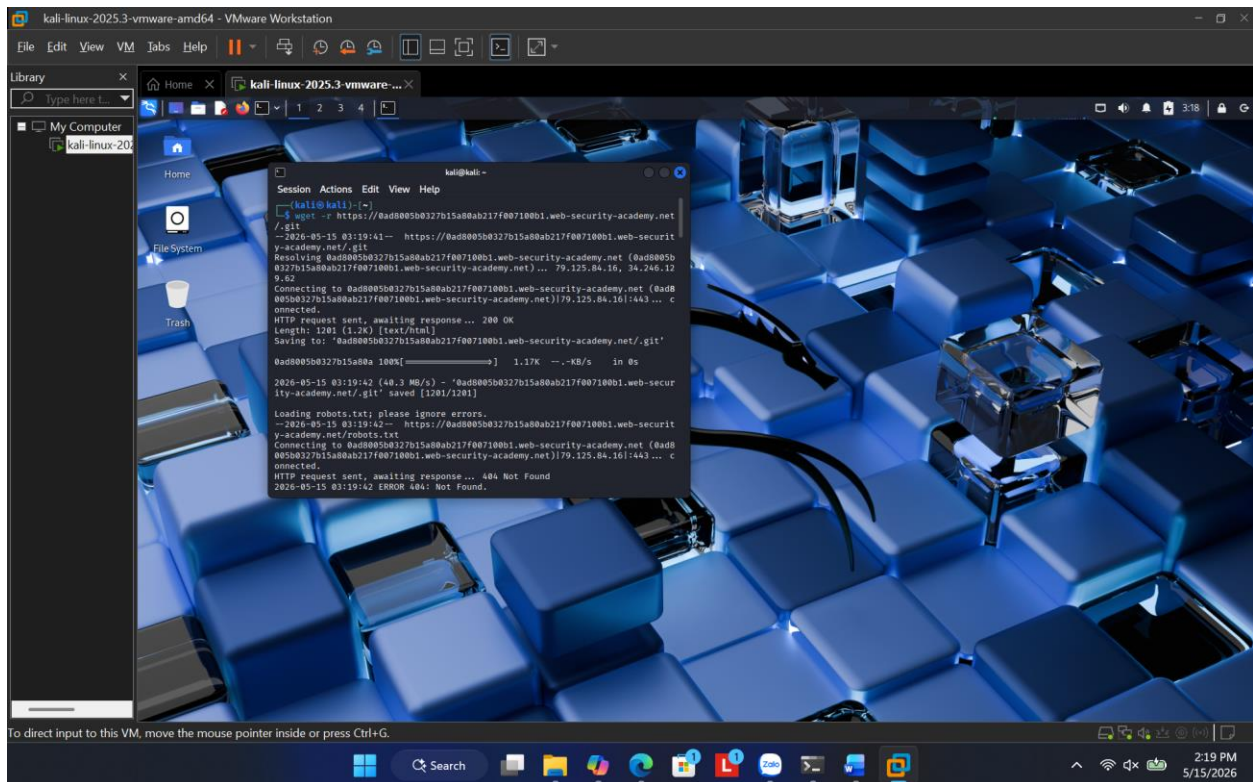
Bước 1. Kiểm tra xem **/.git** có tồn tại hay không



Bước 2. Mở máy ảo kali trên vmware.

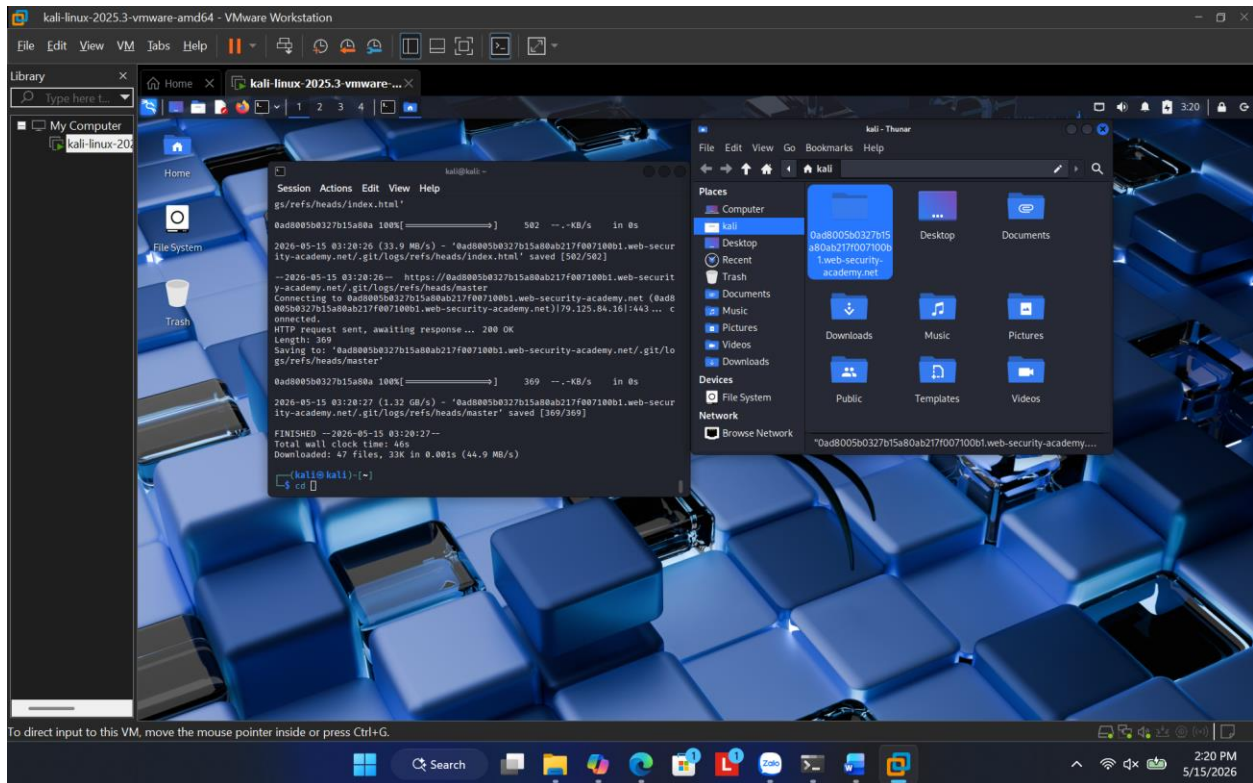


Bước 3. Mở file URL có /.git bằng wget.

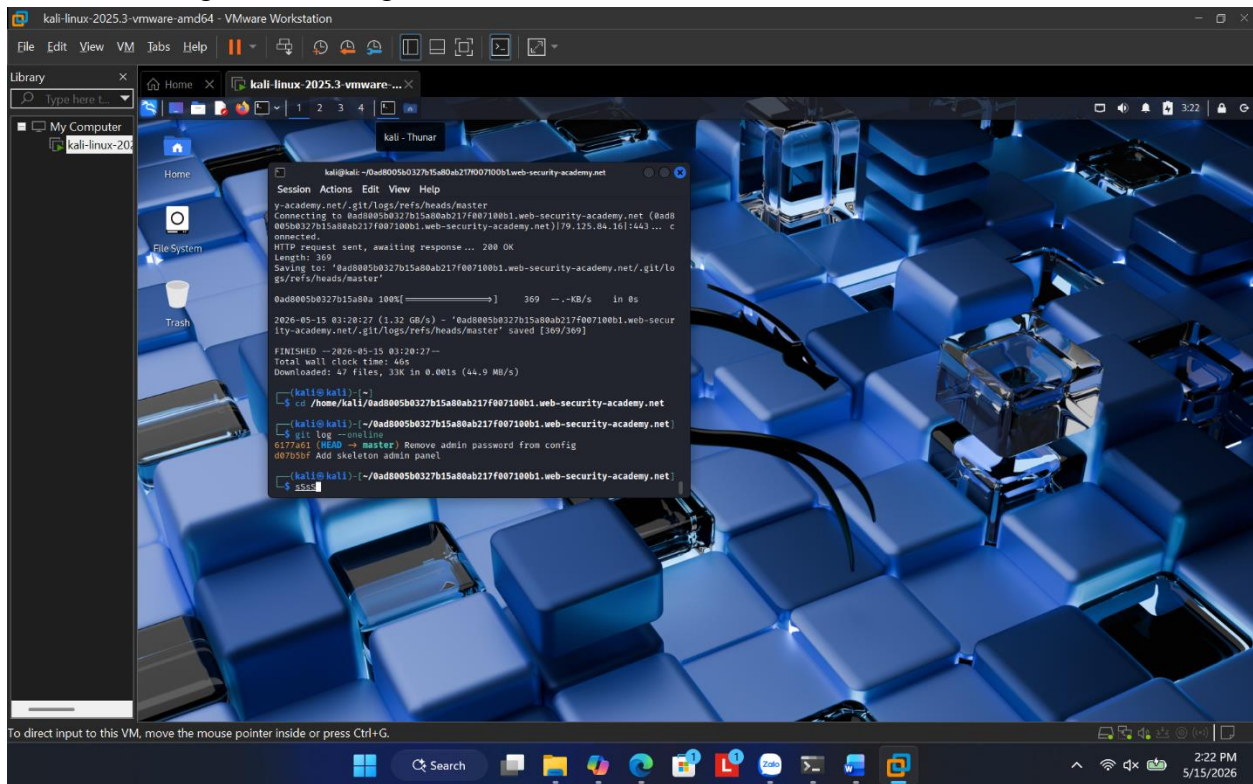


- Tải toàn bộ file trong link URL về.

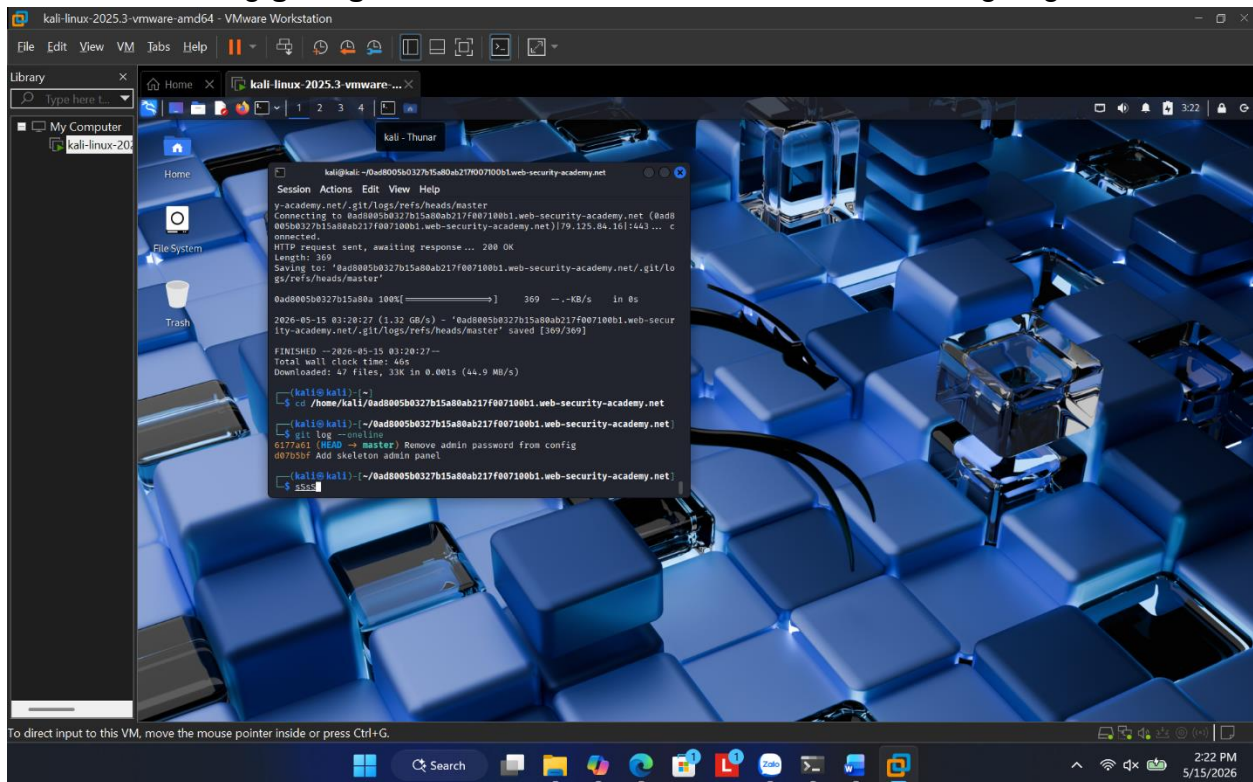
Bước 4. Sau khi chạy xong trong phần home có lab-id.



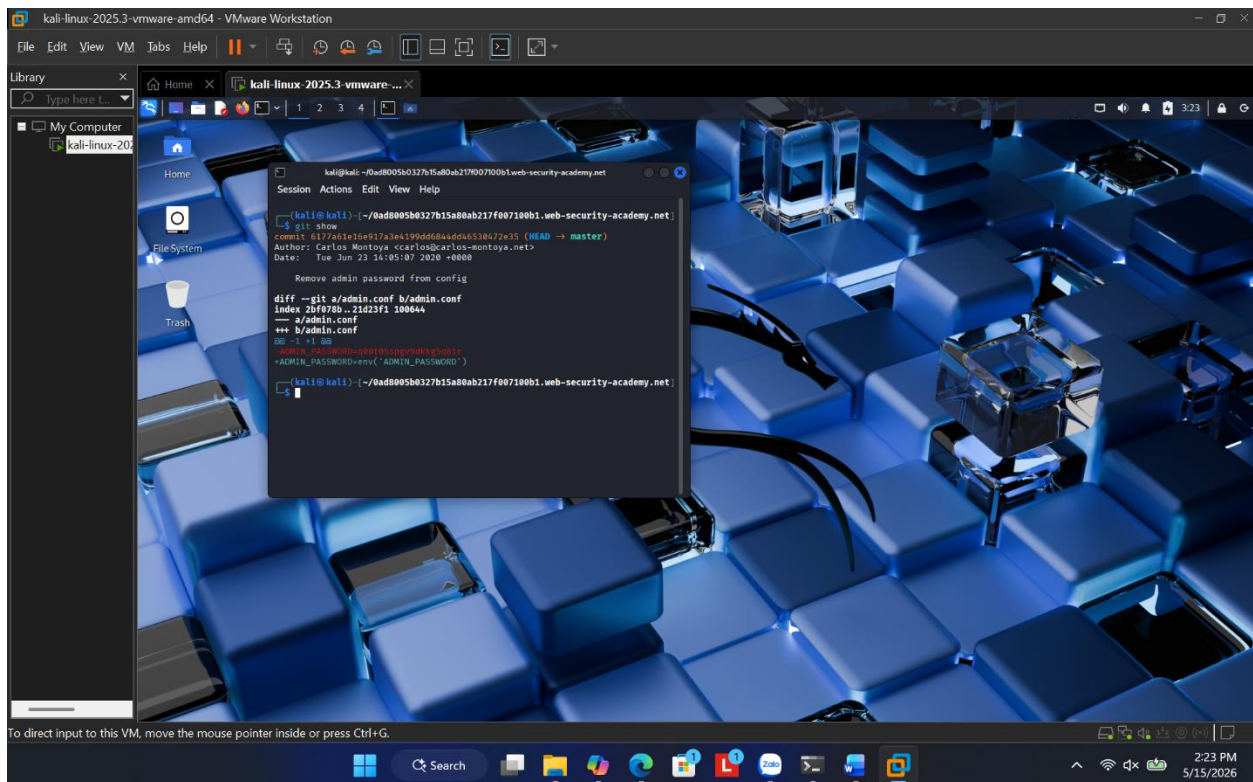
Bước 5. Dùng **cd** trở thẳng tới thư mục của bước 4.



Bước 6. Sử dụng git log –online để tóm tắt lại lịch sử các commit ngắn gọn.



Bước 7. Sử dụng **git show** để show ra toàn bộ nội dung commit trong git.



```
kali@kali: ~/oad0005b0327b15a00ab217f007100b1.web-security-academy.net
git show
commit 6177a51e9517a9e4599d6d6aidd4e538472e35 (HEAD -> master)
Author: Carlos Montoya <carlos@carlos-montoya.net>
Date: Tue Jun 23 14:05:07 2020 +0000

    Remove admin password from config

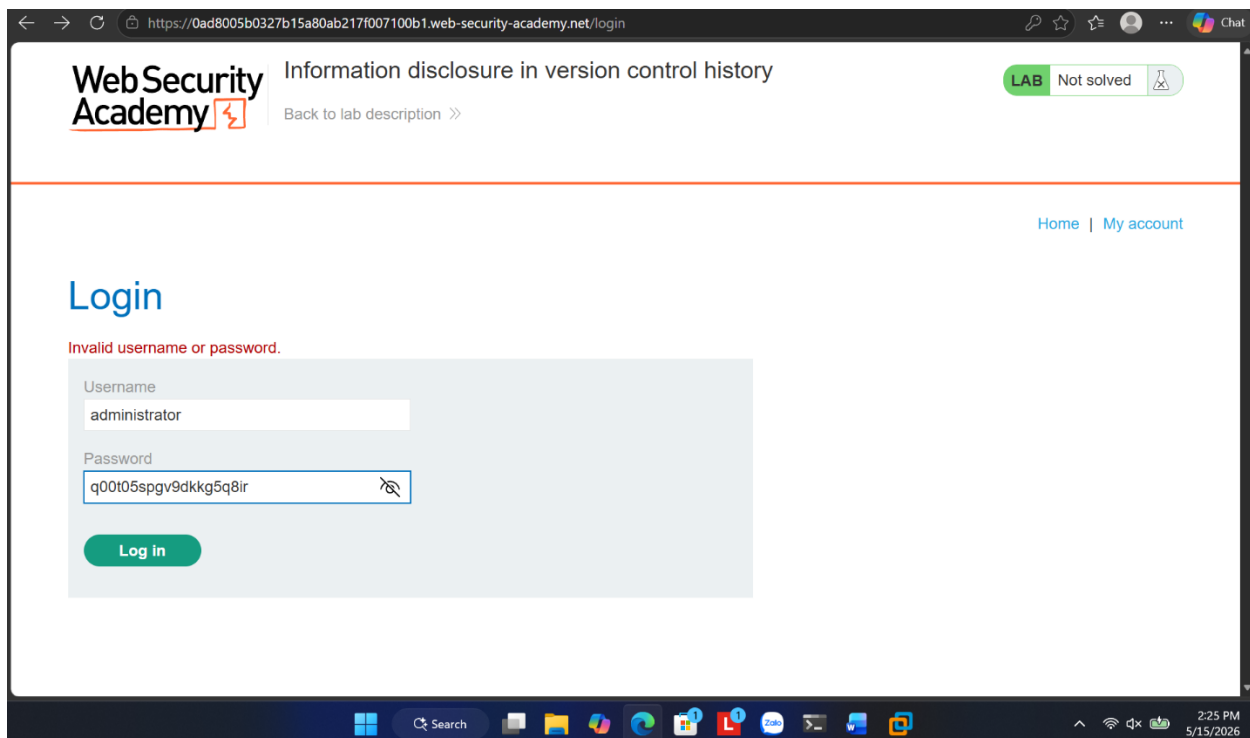
diff --git a/admin.conf b/admin.conf
index 2b9878b..21d23f1 100644
--- a/admin.conf
+++ b/admin.conf
@@ -1,1 @@
-ADMIN_PASSWORD=q00t05spgv9dkkg5q8ir
+ADMIN_PASSWORD=env('ADMIN_PASSWORD')
```

-Sau đó trên màn hình hiển thị

-ADMIN_PASSWORD=q00t05spgv9dkkg5q8ir → đây chính là password.

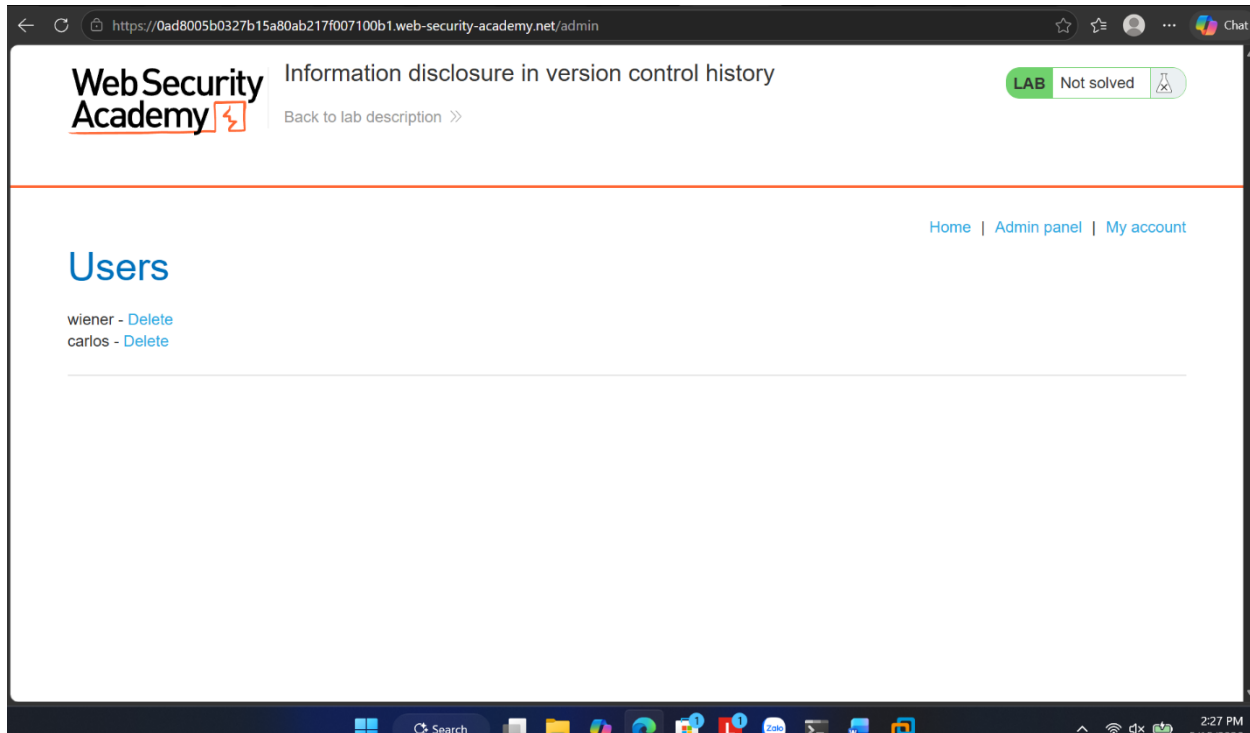
+ADMIN_PASSWORD=env('ADMIN_PASSWORD')

Bước 8. Truy cập lại trang và thêm trên link URL **/login**



-Sau đó nhập user và password như trong kali

Bước 9. Ấn vào Admin panel



Bước 10. Delete Carlos và submit bài lab.

WebSecurity Academy 

Information disclosure in version control history

LAB Solved 

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

[Home](#) | [Admin panel](#) | [My account](#)

User deleted successfully!

Users

wiener - [Delete](#)

2:27 PM
5/15/2026